

4



Módulo 04

Controles de Acesso

Aula 02

Autenticação Baseada em Conhecimento

Introdução —

Nesta aula serão apresentados os conceitos para autenticação baseada em conhecimento:

- Autenticação Local, de rede e remota, para ambientes Windows e Linux;
- Single Sign-On (SSO) e protocolos como PAP, CHAP, MS-Chap Authentication;
- Ataques de senha incluindo força bruta e de dicionário; e
- Estratégias de gerenciamento de autenticação.

Aula 01

Autenticação Baseada em Conhecimento

Implementando Autenticação Baseada em Conhecimento —

IMPLEMENTANDO AUTENTICAÇÃO BASEADA EM CONHECIMENTO

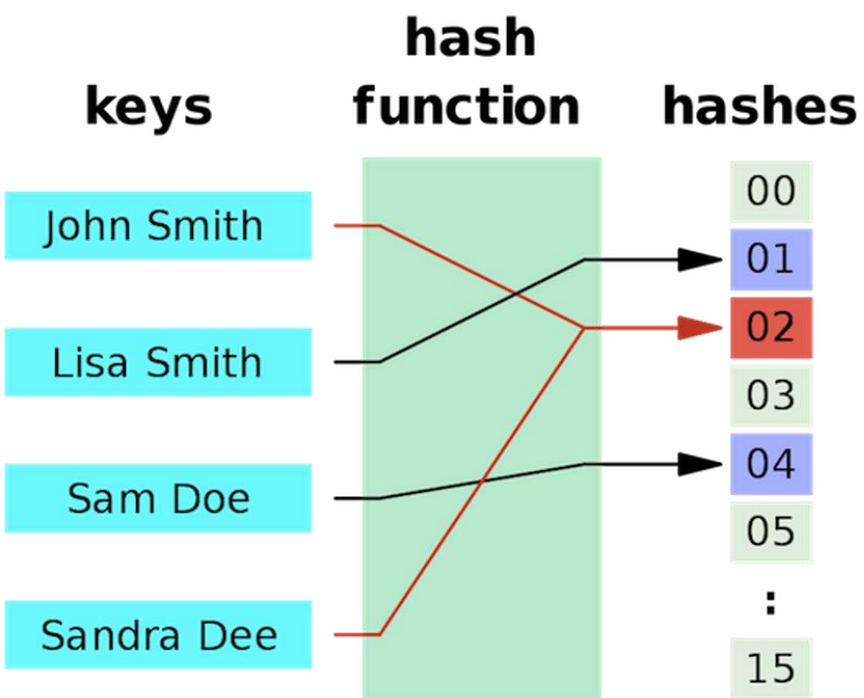
- Refere-se principalmente à criação de credenciais de usuários com mecanismos de acesso à conta baseados em senha.
- Inclui ainda a configuração de protocolos de autenticação baseados em senha.
- Fornecer suporte a usuários com problemas de autenticação também é parte dessa função.

AUTENTICAÇÃO LOCAL, DE REDE E REMOTA

Provedor de autenticação:

- É um dos recursos mais importantes de um sistema operacional.
- É a arquitetura de software e o código que sustenta o mecanismo pelo qual o usuário é autenticado antes de iniciar uma atividade.
- O provedor de autenticação padrão para a maioria dos sistemas operacionais é baseado em conhecimento (senha ou PIN).
- O processo é descrito como login (Linux) ou logon ou sign-in (Microsoft).





Fonte: Wikipédia

Disponível em:

<https://pt.wikipedia.org/wiki/Fun%C3%A7%C3%A3o_hash>.

Acesso em: 25 mar. 2024.

AUTENTICAÇÃO LOCAL, DE REDE E REMOTA

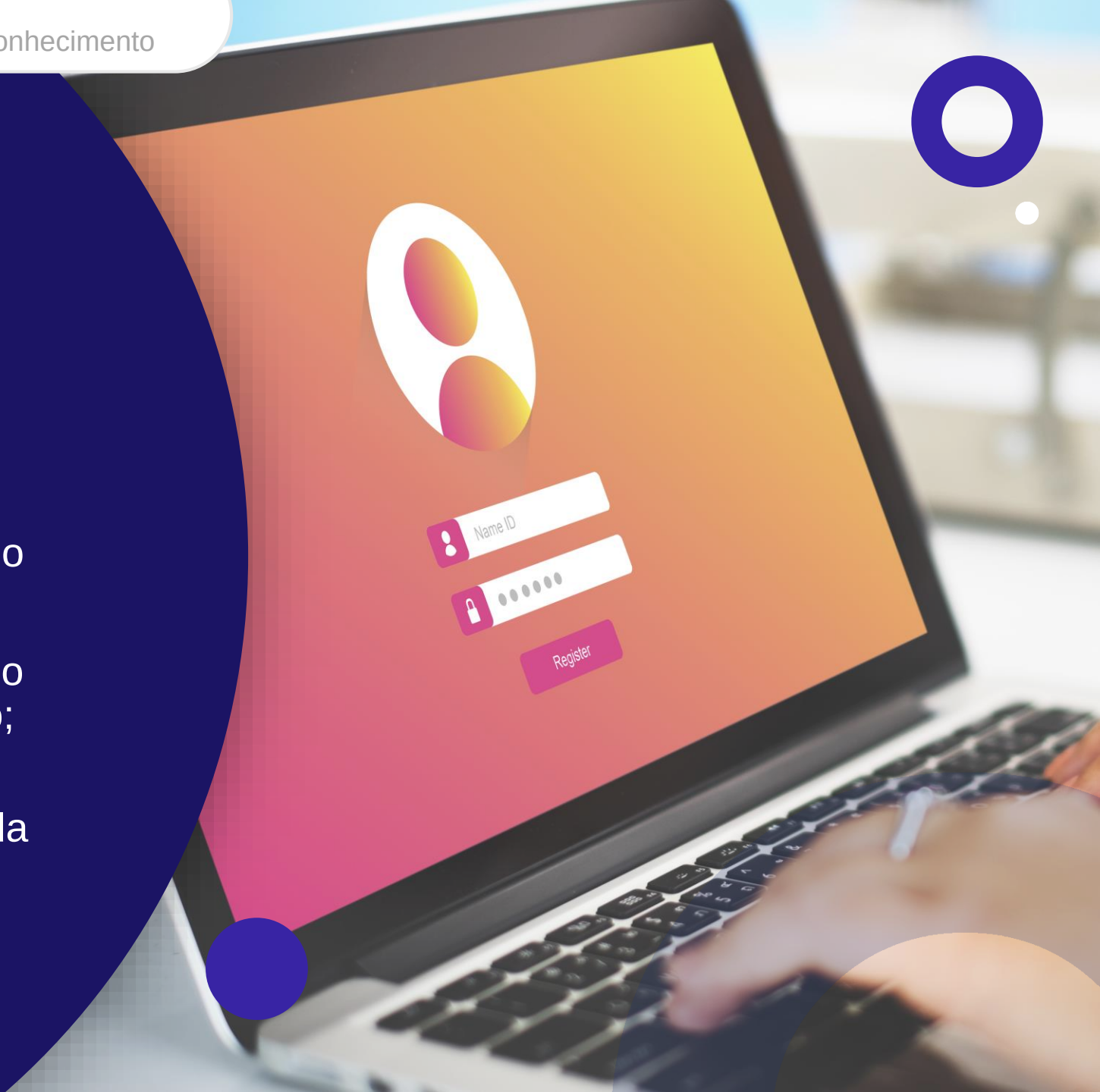
Hash criptográfico:

- A autenticação baseada em conhecimento depende de *hashes*.
- A senha é armazenada em bancos de dados como um *hash* criptográfico.
- O autenticador converte a senha digitada em um *hash* e transmite para a autoridade que compara o *hash* enviado com o do banco de dados.
- Autentica somente se houver correspondência entre eles.

AUTENTICAÇÃO LOCAL, DE REDE E REMOTA

- O processo de login:

- São as etapas pelas quais um usuário solicita acesso a um sistema em TI:
 1. Identificação do usuário: Usuário fornece um identificador exclusivo;
 2. Fornecimento de Credenciais: Usuário informa a senha associada ao identificador;



AUTENTICAÇÃO LOCAL, DE REDE E REMOTA

3. Envio das credenciais ao sistema de autenticação **local ou remoto**;
4. Validação das credenciais;
5. Concessão de acesso.
6. Criação de sessão.



Fonte: Salesforce
Disponível em: <https://trailhead.salesforce.com/pt-BR/content/learn/modules/identity_external/identity_external_social>
Acesso em: 25 mar. 2024.

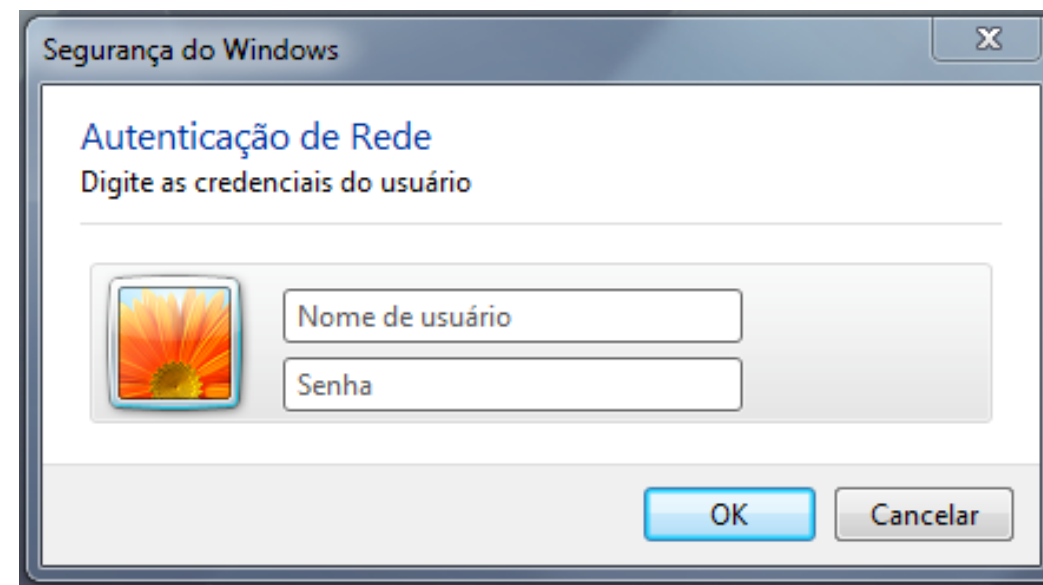


AUTENTICAÇÃO LOCAL

- Refere-se ao processo de verificar a identidade de um usuário em um dispositivo específico.
- Pode ser um computador pessoal ou um dispositivo móvel.
- O usuário interage diretamente com o sistema.
- Um exemplo está na autenticação biométrica, como leitores de impressões digitais em smartphones para liberação do acesso local.

AUTENTICAÇÃO DE REDE

- Inclui o acesso a recursos compartilhados em uma rede corporativa.
- A verificação de identidade ocorre em um servidor central.
- Por exemplo, em ambiente corporativos:
 1. No sistema MS-Windows é o Active Directory (AD).
 2. O uso do protocolo LDAP (Lightweight Directory Access Protocol) para autenticar usuários em um servidor centralizado.





Fonte: Eduardo Mozart

Disponível em:

<<https://eduardomozartdeoliveira.wordpress.com/2016/12/14/autenticacao-em-nivel-de-rede-nla/>>

Acesso em: 25 mar. 2024.

AUTENTICAÇÃO REMOTA

- A validação da identidade de usuários permite acessar recursos em locais geograficamente distantes.
- É essencial em organizações com equipes distribuídas regionalmente ou com trabalhadores remotos.
- Por exemplo, o uso de VPN (Virtual Private Network) para usuários remotos, permitindo a autenticação remota como se estivessem fisicamente na sede da empresa.



AUTENTICAÇÃO NO WINDOWS E LINUX

1 Autenticação no Windows

- Sign-in Local:

1. A Autoridade de Segurança Local (LSA) compara a credencial enviada a um *hash* armazenado no banco de dados do Security Accounts Manager (SAM).

- Autenticação de rede:

1. Gerenciada pelo Active Directory (AD).
2. O LSA passa as credenciais para um serviço de rede, em geral, baseado em Kerberos.



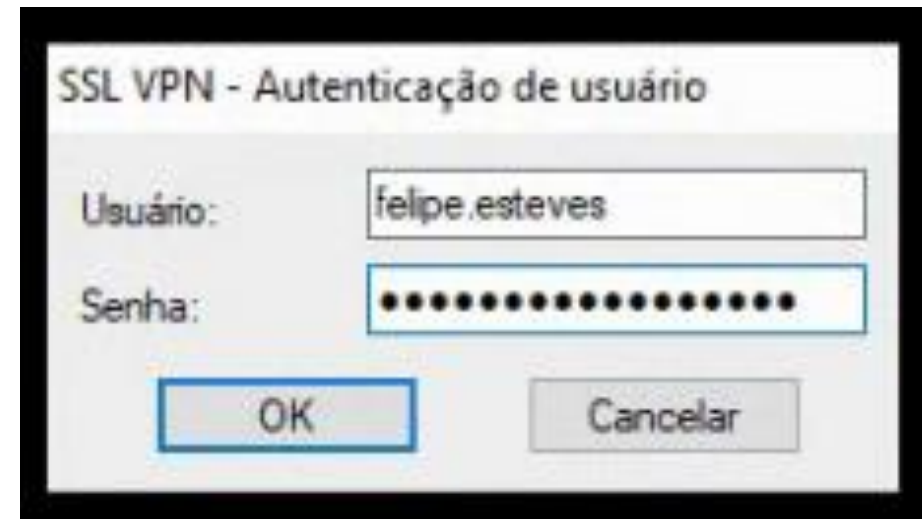
Fonte: Microsoft Infrastructure, Virtualization & System Management
Disponível em: <<https://pkjayan.wordpress.com/2013/09/30/kerberos-authentication-technology-simplified-2/>>.
Acesso em: 25 mar. 2024.

AUTENTICAÇÃO NO WINDOWS E LINUX

- Autenticação remota no Windows

1. Podem ser adotadas tecnologias como o Protocolo de Área Segura (SSTP) para VPNs.

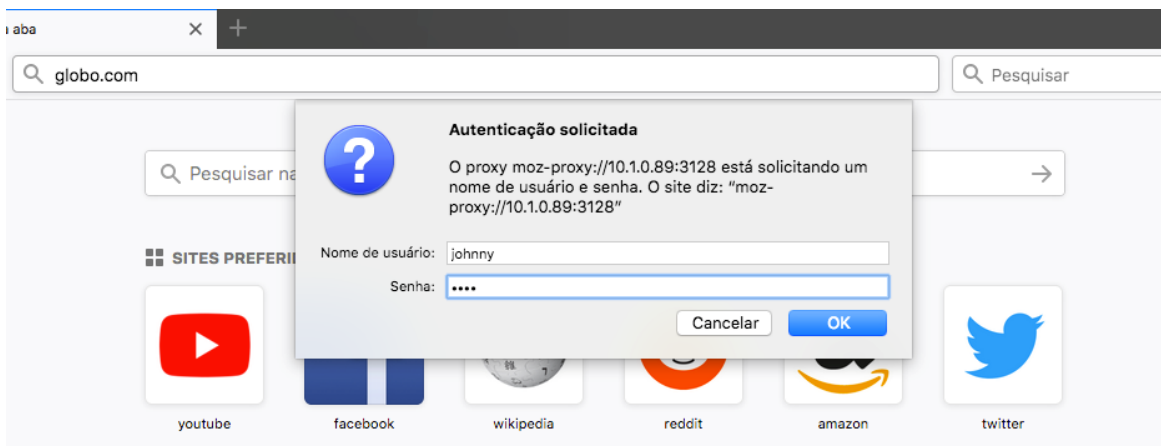
2. Os usuários remotos autenticam-se por meio de uma conexão segura, geralmente utilizando certificados digitais ou outros métodos seguros.



Fonte: Documentação SciELO

Disponível em: <<https://documentacao.scielo.org/books/manuais-publicos/page/cadastro-de-usuario>>

Acesso em: 25 mar. 2024.



Fonte: TI da Hora!

Disponível em: <<https://tidahora.com.br/servidor-proxy-squid-no-linux-centos-7-com-autenticacao-local/>>.

Acesso em: 25 mar. 2024.

AUTENTICAÇÃO NO WINDOWS E LINUX

2 Autenticação no Linux

- Login local:

1. O arquivo `/etc/passwd` guarda as credenciais das contas de usuários.
2. O `/etc/shadow` guarda o *hash* das senhas.

SSH Server Authentication

SSH Server Authentication: ☒ Enable

IPv4 Source Interface:

Auto

IPv6 Source Interface:

Auto

VLAN 1

Fonte: Cisco

Disponível em:

<https://www.cisco.com/c/pt_br/support/docs/smb/switches/Cisco-Business-Switching/kmgmt-2776-configure-secure-shell-ssh-server-authentication-settings-cbs.html>.

Acesso em: 25 mar. 2024.

AUTENTICAÇÃO NO WINDOWS E LINUX

- Autenticação de rede:

1. Pode ser realizado usando Secure Shell (SSH) e chaves criptográficas em vez de senha.
2. Pode ser utilizando o Pluggable Authentication Modules (PAM) o que permite flexibilidade na escolha de métodos de autenticação para serviços de rede.
3. Além disso, a integração com serviços de diretório, como o LDAP, pode ser implementada para autenticar usuários em uma rede centralizada.

Linux User Authentication

PAM

NSS

SSSD



AUTENTICAÇÃO NO WINDOWS E LINUX

- Autenticação remota:
 1. Usuários remotos autenticam-se usando chaves SSH ou senhas.
 2. A estrutura PAM também pode ser usada para implementar autenticação em servidores de redes.

SINGLE SIGN-ON (SSO)

- É uma solução de autenticação que permite que um usuário acesse vários sistemas ou aplicativos com uma única autenticação.
- Simplifica a experiência do usuário.
- Reduz o número de senhas que um usuário precisa gerenciar.

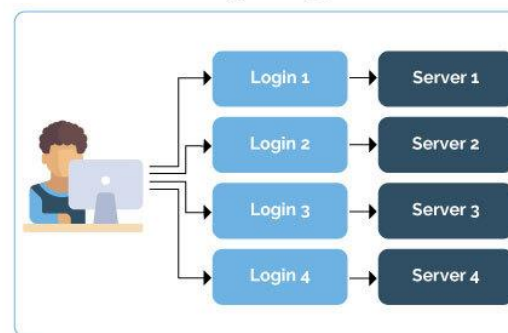


SINGLE SIGN-ON (SSO)

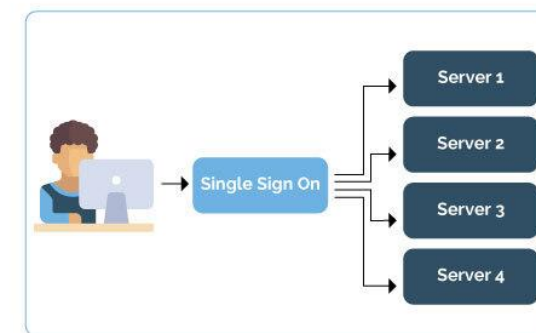
— Etapas do Processo de Single Sign-On:

1. Autenticação inicial em um dos serviços conectados ao sistema SSO;
2. Emissão de Token de Sessão;
3. Armazenamento Seguro do Token;
4. Acesso a Outros Serviços;
5. Renovação de Token;
6. Logout Único (Single Logout).

Without Single Sign On (SSO)



With SSO

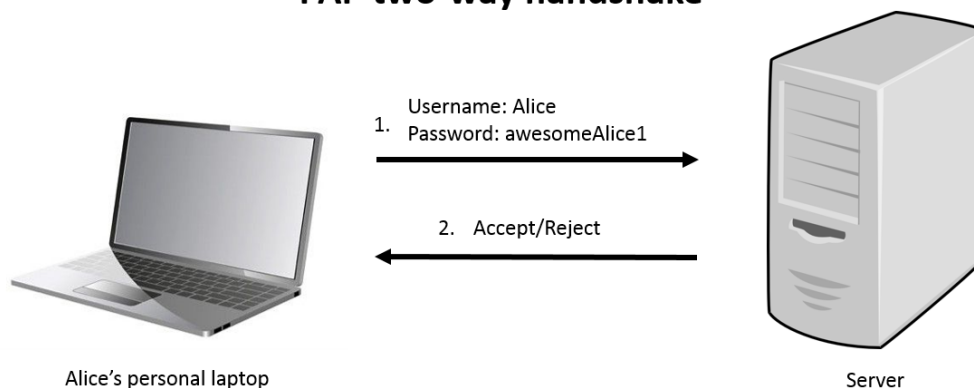


Fonte: Gyoumagazine

Disponível em:

<https://pt.gyoumagazine.com/article/single_sign_on_sso_what_is_it_and_should_you_use_it>

Acesso em: 25 mar. 2024.

PAP two-way handshake

Fonte: Medium

Disponível em:

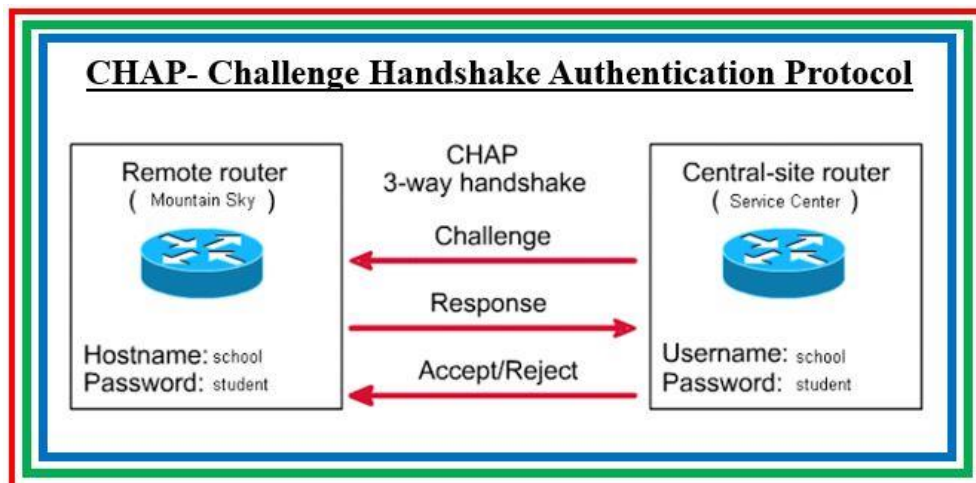
<<https://medium.com/@gabriellaakubueze115/authentication-protocols-60baaba1281f>>

Acesso em: 25 mar. 2024.

PROTOCOLOS DE AUTENTICAÇÃO (PAP, CHAP, MS-CHAP)

1 PAP (Password Authentication Protocol)

- É um protocolo de autenticação simples;
- As credenciais (nome de usuário e senha) são enviadas ao servidor de autenticação em texto aberto.
- Caindo em desuso devido à falta de segurança.
- Utilizado em redes dial-up e como mecanismo de autenticação em HTTP.



Fonte: The Network DNA

Disponível em:

<<https://www.thenetworkdna.com/2020/12/introduction-to-p2p-authentication-pap.html>>

Acesso em: 25 mar. 2024.

PROTOCOLOS DE AUTENTICAÇÃO (PAP, CHAP, MS-CHAP)

2 CHAP (Challenge Handshake Authentication Protocol)

- É um protocolo de autenticação mais seguro que o PAP.
- O servidor envia um desafio ao cliente, que responde com uma versão criptografada da senha combinada com o desafio.
- Usado em conexões PPP (Point-to-Point Protocol) em redes dial-up e VPNs.

MS-CHAP Challenge-Response Authentication Protocol

4. Applicant Sends Response Message

Transmitted Response

Password

Challenge

Hashing

Expected Response

5.

Verifier

Adds password to the challenge message it sent. Hashes the combination. This should be the expected response message.

45

Fonte: University of Baltimore

Disponível em:

<<http://home.ubalt.edu/abento/427/security/sld045.htm>>.

Acesso em: 25 mar. 2024.

PROTOCOLOS DE AUTENTICAÇÃO (PAP, CHAP, MS-CHAP)

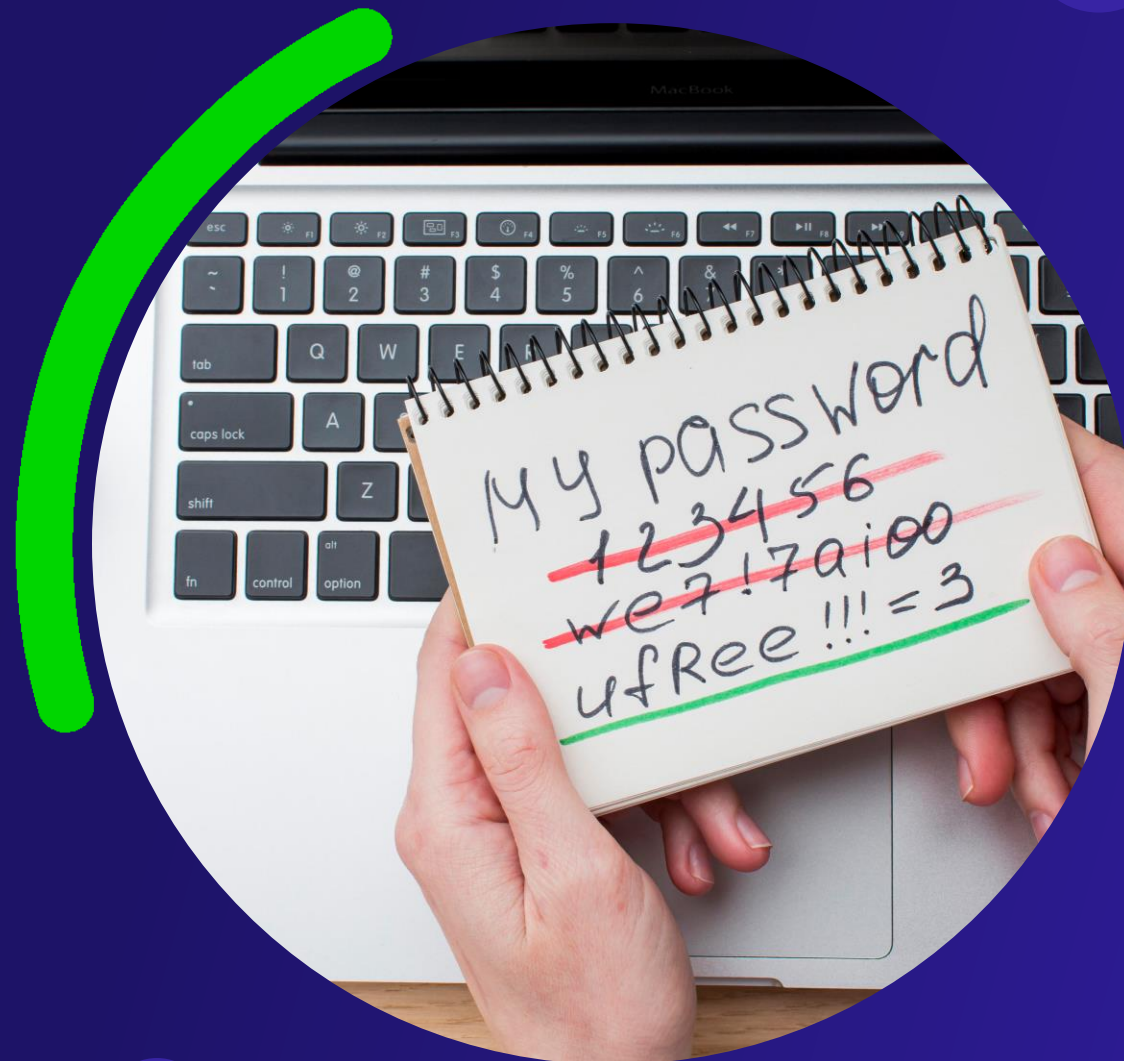
3 MS-CHAP (Microsoft Challenge Handshake Authentication Protocol)

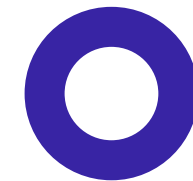
- É uma variação do CHAP desenvolvida pela Microsoft.
- Adicionou suporte à troca de senhas criptografadas.
- Usado em ambientes Microsoft, especialmente em VPNs.

ATAQUES DE SENHA

Tipos de ataques de senha:

- 1 Ataque de texto simples/não criptografado (*plaintext/unencrypted attack*)
 - Ocorre se as senhas são transmitidas ou armazenadas sem criptografia.
 - Os atacantes podem interceptar ou acessar diretamente essas senhas.
 - Os exemplos incluem PAP, autenticação HTTP/FTP básica e Telnet.





Fonte: Diego Macêdo
Disponível em: <<https://www.diegomacedo.com.br/quebra-de-senha-ataques-passivos-online/>>.
Acesso em: 25 mar. 2024.

ATAQUES DE SENHA

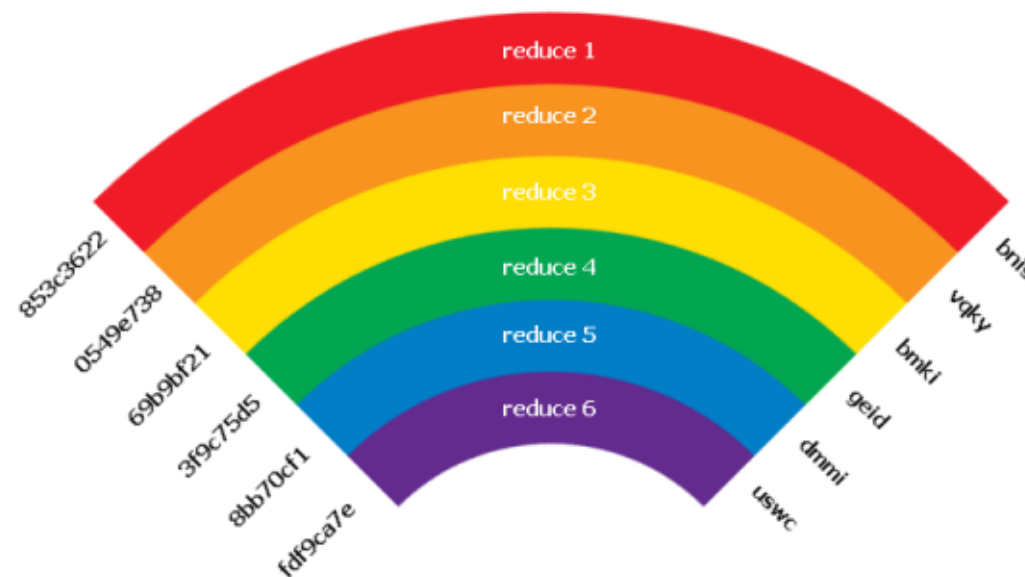
2 Ataques online

- O agente da ameaça interage diretamente no serviço de autenticação.
- Envolve tentativas automáticas e contínuas de login em uma conta, geralmente usando força bruta ou dicionário.
- Atacantes exploram a capacidade de realizar tentativas repetidas para encontrar a combinação correta de nome de usuário e senha.

ATAQUES DE SENHA

3 Pulverização de senhas

- O invasor escolhe uma ou mais senhas comuns (por exemplo, “senha” ou “123456”) e as testa em conjunto com vários nomes de usuário.
- Limita as tentativas por conta e evita bloqueios automáticos, tornando mais difícil a detecção de atividades suspeitas.



Fonte: Diego Macêdo

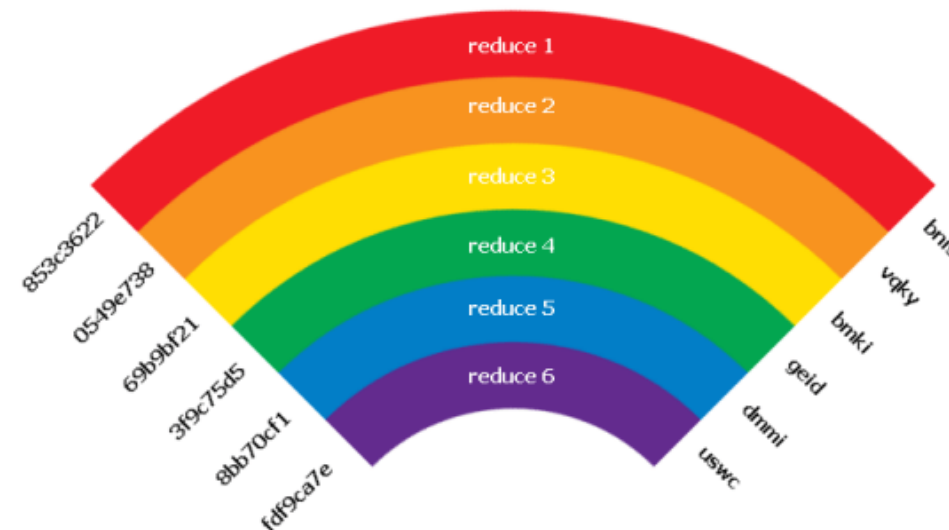
Disponível em: <<https://www.diegomacedo.com.br/quebra-de-senha-ataques-off-line/>>

Acesso em: 25 mar. 2024.

ATAQUES DE SENHA

4 Ataque offline

- O invasor conseguiu obter um banco de dados de *hashes* de senha.
- Usa técnicas offline, tentativas de quebra sem interação com o sistema alvo, como ataques de força bruta ou dicionário.



Fonte: Diego Macêdo¹.

¹ Disponível em: <<https://www.diegomacedo.com.br/quebra-de-senha-ataques-off-line/>>.
Acesso em: 25 mar. 2024.

ATAQUES DE SENHA

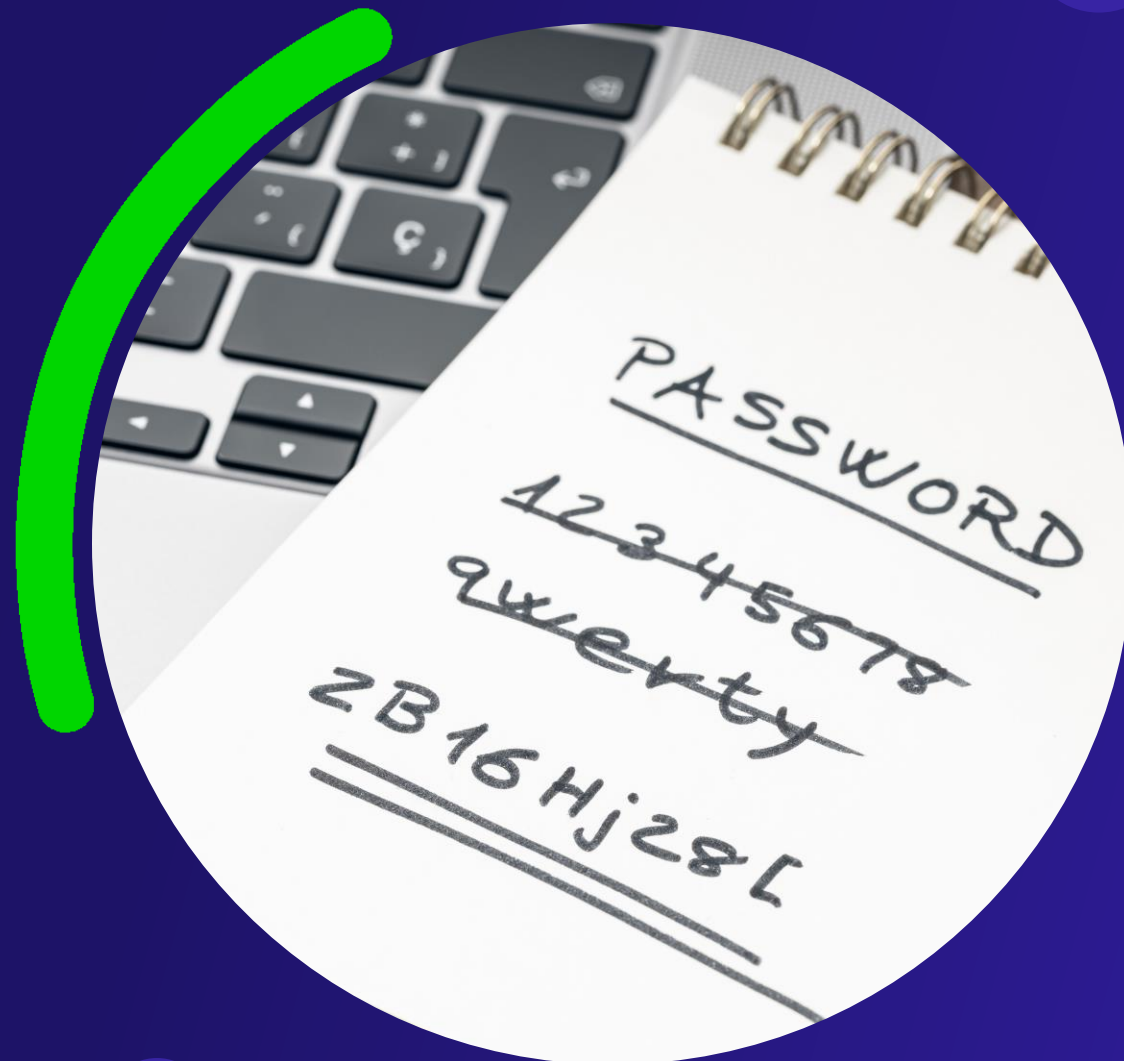
5 Ataques de Força Bruta

- Tenta todas as combinações possíveis no espaço de saída para corresponder a um *hash* capturado e adivinhar o texto que o gerou.
- O espaço de saída é determinado pelo número de bits usados pelo algoritmo (MD5 de 128 bits ou SHA256 de 256 bits, por exemplo).
- Necessita recursos computacionais.
- São mais eficazes na quebra de senhas curtas.

ATAQUES DE SENHA

6 Ataques de dicionário:

- Usam uma lista de palavras comuns.
- O software gera valores de *hash* a partir de um dicionário de textos simples para tentar combinar com o *hash* capturado.
- Atacantes exploram a previsibilidade de senhas comuns ou sequências alfanuméricas, tentando exaustivamente todas as combinações.



ATAQUES DE SENHA

7 Ataque Híbrido

- Usa uma combinação de ataques de dicionário e de força bruta.
- O algoritmo de quebra de senha testa palavras e nomes de dicionário em combinação com uma máscara que limita o número de variações a serem testadas, como a adição de prefixos e/ou sufixos numéricos.
- Os atacantes buscam equilibrar a eficiência de um ataque de força bruta com a previsibilidade de padrões de senha comuns.



GERENCIAMENTO DE AUTENTICAÇÃO

— Cenário:

- Usuários adotam práticas inadequadas e difíceis de controlar.
- Por exemplo, usar a mesma senha para rede e sites de consumidores.
- Isto gera vulnerabilidade.



Fonte: Minuto da Segurança

Disponível em: <<https://minutodaseguranca.blog.br/cofre-de-senhas-sugestoes-para-uma-implementacao-bem-sucedida/>>

Acesso em: 25 mar. 2024.

GERENCIAMENTO DE AUTENTICAÇÃO

— Solução:

- Uma solução de gerenciamento de autenticação para senhas mitiga esse risco usando um dispositivo ou serviço como proxy para armazenamento de credenciais:
 1. Chave de senha: Tokens USB para conexão com PCs e smartphones.
 2. Cofres de senhas: Gerenciador de senhas baseado em software.



4



Você chegou ao final da Aula 02
**Autenticação Baseada em
Conhecimento**